

Chapter 11

2026 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드

가상화 장비

1. 계정 관리	790
2. 시스템 서비스 관리	812
3. 가상 머신 관리	837
4. 가상 네트워크 관리	845

01 가상화 장비 취약점 분석 · 평가 항목

1. 계정 관리

점검항목	항목 중요도	항목코드
계정 로그오프/세션 관리	상	HV-01
가상화 장비 외부접속 차단	상	HV-02
가상화 장비 루트계정 관리	상	HV-03
가상화 장비 계정 권한 관리	상	HV-04
가상화 장비 사용자 인증 강화	상	HV-05
비밀번호 관리정책 설정	상	HV-06
계정 잠금 임계값 설정	상	HV-07

2. 시스템 서비스 관리

점검항목	항목 중요도	항목코드
시스템 사용 주의사항 출력 설정	중	HV-08
NTP 및 시각 동기화 설정	중	HV-09
SNMP Community String 복잡성 적용	중	HV-10
MOB(Managed Object Browser) 서비스 비활성화	상	HV-11
ESXi Shell 비활성화	상	HV-12
ESXi Shell 세션 종료 시간 설정	상	HV-13
원격 로그 서버 이용	중	HV-14
시스템 주요 이벤트 로그 설정	상	HV-15
비휘발성 경로 내 로그 파일 저장	상	HV-16

11. 가상화 장비

3. 가상 머신 관리

점검항목	항목 중요도	항목코드
코어덤프 수집 기능 활성화	상	HV-17
가상 머신의 장치 변경 제한 설정	상	HV-18
가상 머신의 불필요한 장치 제거	상	HV-19
가상 머신 콘솔 클립보드 복사&붙여넣기 기능 비활성화	상	HV-20
가상 머신 콘솔 드래그 앤 드롭 기능 비활성화	상	HV-21

4. 가상 네트워크 관리

점검항목	항목 중요도	항목코드
가상 스위치 MAC 주소 변경 정책 비활성화	상	HV-22
가상 스위치 무차별(Promiscuous) 모드 정책 비활성화	상	HV-23
가상 스위치 위조전송(Forged Transmits) 모드 정책 비활성화	상	HV-24
주기적 보안 패치 및 벤더 권고사항 적용	상	HV-25

HV-01 (상)	가상화 장비 > 1. 계정 관리
	계정 로그오프/세션 관리
개요	
점검 내용	웹 콘솔 및 사용자 Shell Session Timeout 설정 여부 점검
점검 목적	Session Timeout 기능을 구현하여 공격자가 만료되지 않은 세션 활용을 방지하기 위함
보안 위협	세션의 만료 기간을 정하지 않거나, 만료기한이 너무 길게 설정된 경우 악의적인 사용자가 만료되지 않은 세션을 활용하여 불법적인 접근을 시도할 수 있는 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : 웹 콘솔 및 사용자 Shell Session Timeout 설정이 600초(10분) 이하로 설정된 경우
	취약 : 웹 콘솔 및 사용자 Shell Session Timeout 설정이 600초(10분)를 초과하여 설정된 경우
조치 방법	600초(10분) 동안 입력이 없을 경우 접속된 클라이언트 세션을 끊도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● VMware ESXi, vCenter

[웹 콘솔 Session Timeout 설정]

Step 1) Web 콘솔 페이지 접속

https://<VMware ESXi IP>

Step 2) 호스트 > 관리 > 시스템 > 고급 설정으로 이동

Step 3) UserVars.HostClientSessionTimeout 설정이 600초(10분)로 설정되어 있는지 확인



[웹 콘솔 Session Timeout 설정 확인]

11. 가상화 장비

Step 4) 600초(10분) 이하로 설정되어 있지 않은 경우 [옵션 편집]을 클릭하여 아래와 같이 수정

[옵션 값 수정]

● XenServer, KVM

[사용자 Shell Session Timeout 설정]

Step 1) 호스트에 접속

Step 2) echo \$TMOUT 명령어를 이용하여 사용자 Shell Session Timeout 설정 확인

```
$ echo $TMOUT
9000
```

Step 3) Session Timeout 10분을 초과하는 경우 아래 두 라인 추가

```
$ vi /etc/profile
readonly TMOUT=600;
export TMOUT
```

Step 4) 변경된 설정 적용

```
$ source /etc/profile
```

● Nutanix

[사용자 Shell Session Timeout 설정]

Step 1) Controller VM에 접속하여 User Shell Session Timeout 설정 확인

```
sudo cat /etc/profile.d/os-security.sh
```

```
readonly TMOUT=9000 2> /dev/null || echo "TMOUT already set."
readonly HISTFILE
mesg n 2>/dev/null
```

Step 2) vi 편집기를 이용하여 User Shell Session Timeout을 10분으로 설정

```
sudo vi /srv/salt/security/CVM/shellCVM.sls
```

```
ossecuritycreate:
  file:
    - managed
    - name: /etc/profile.d/os-security.sh
    - mode: 644
    - user: root
    - group: root
    - contents: |
        readonly TMOUT=600 2> /dev/null || echo "TMOUT already set."
```

Step 3) 변경된 설정 적용

```
sudo salt-call state.sls security/CVM/shellCVM
```

[SSH Idle Timeout 설정]

Step 1) Controller VM에 접속하여 SSH Idle Timeout 설정 확인

```
sudo cat /etc/ssh/sshd_config | grep "ClientAliveInterval"
```

Step 2) vi 편집기를 이용하여 SSH Idle Timeout을 10분으로 설정

```
sudo vi /srv/salt/security/CVM/sshd/sshdconfCVM
```

```
ClientAliveInterval 600
```

Step 3) 변경 설정 적용

```
sudo salt-call state.sls security/CVM/sshdCVM
```

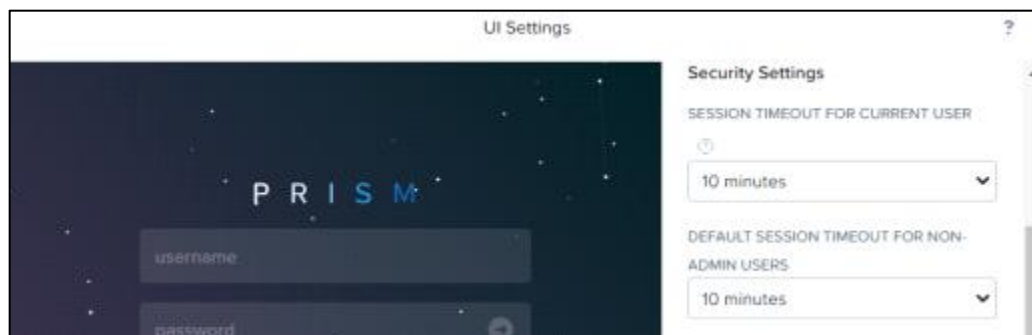
[관리 웹 콘솔 Session Timeout 설정]

Step 1) 관리 웹 콘솔 접속

<https://<Nutanix 웹 콘솔 IP:9440>>

Step 2) Session Timeout 설정 적용

Settings > UI Settings > Security Setting의 SESSION TIMTOUT 설정을 10분으로 설정



11. 가상화 장비

HV-02 (상)	가상화 장비 > 1. 계정 관리
	가상화 장비 외부접속 차단
개요	
점검 내용	허용할 호스트에 대한 접속 IP 제한 설정 여부 점검
점검 목적	허용한 호스트만 서비스를 사용하게 하여 비인가자의 무단 접근 시도를 예방하기 위함
보안 위협	호스트에서 실행되는 서비스에 대한 접근을 제한하지 않으면 비인가자의 무단 접근에 노출되어 가상화 시스템 침해사고의 위험이 존재함
참고	※ TCP Wrapper : 호스트 기반의 네트워킹 ACL(Access Control List) 시스템 ※ IPTables : 리눅스 커널 방화벽이 제공하는 테이블들과 그것을 저장하는 체인, 규칙들을 구성할 수 있게 해주는 서비스 ※ FirewallID : Linux 운영체제를 위한 방화벽 관리 도구
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : 허용된 IP에서만 관리 콘솔 및 원격 접속이 가능하도록 제한된 경우
	취약 : 허용된 IP에서만 관리 콘솔 및 원격 접속이 가능하도록 제한되지 않은 경우
조치 방법	호스트에서 제공하는 방화벽 애플리케이션을 이용하여 서비스 접속 허용 IP 등록 설정
조치 시 영향	IPTables의 기본 정책을 Drop으로 변경하는 경우에는 애플리케이션 간의 연결 현황을 확인 후 변경이 필요함

점검 및 조치 사례

● VMware ESXi, vCenter

[웹 콘솔 접속 IP 제한 설정]

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 네트워킹 > 방화벽 규칙으로 이동

Step 3) [ESXi] SSH 서버 “허용된 IP주소” 확인

Step 4) [vSphere] 웹 클라이언트 “허용된 IP주소” 확인



[허용된 IP주소 확인]

Step 5) IP 제한 설정이 적용되어 있지 않은 경우 vSphere Web Client(SSH 서버) > 설정 편집 > 다음 네트워크의 연결만 허용 선택

Step 6) 접속 허용 IP 입력

[접속 허용 IP 입력]

● XenServer, KVM

[IPTables를 통한 접근 통제]

Step 1) 호스트 접속

```
$ iptables -nL --line-number
Chain INPUT (policy ACCEPT)
num target prot opt source destination
1 xapi_nbd_input_chain tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:10809
2 ACCEPT 47 -- 0.0.0.0/0 0.0.0.0/0
3 RH-Firewall-1-INPUT all -- 0.0.0.0/0 0.0.0.0/0
... 중간 생략 ...
Chain RH-Firewall-1-INPUT (2 references)
num target prot opt source destination
1 ACCEPT all -- 0.0.0.0/0 0.0.0.0/0
2 ACCEPT icmp -- 0.0.0.0/0 0.0.0.0/0 icmp type 255
3 ACCEPT udp -- 0.0.0.0/0 0.0.0.0/0 udp dpt:67
4 ACCEPT all -- 0.0.0.0/0 0.0.0.0/0 ctstate RELATED,ESTABLISHED
5 ACCEPT udp -- 0.0.0.0/0 0.0.0.0/0 ctstate NEW udp dpt:694
```


11. 가상화 장비

```
6 ACCEPT tcp -- 0.0.0.0/0 0.0.0.0/0 ctstate NEW tcp dpt:22
7 ACCEPT tcp -- 0.0.0.0/0 0.0.0.0/0 ctstate NEW tcp dpt:80
8 ACCEPT tcp -- 0.0.0.0/0 0.0.0.0/0 ctstate NEW tcp dpt:443
9 ACCEPT tcp -- 0.0.0.0/0 0.0.0.0/0 tcp dpt:21064
10 ACCEPT udp -- 0.0.0.0/0 0.0.0.0/0 multiport dports 5404,5405
11 REJECT all -- 0.0.0.0/0 0.0.0.0/0 reject-with icmp-host-prohibited
```

Step 2) IPTables 정책 목록을 통해 접속 IP 제한 설정 확인

Step 3) SSH 원격 접속을 허용된 IP로만 제한

```
$ iptables -I RH-Firewall-1-INPUT 1 -p tcp -s <허용 IP> --dport 22 -j
ACCEPT
$ iptables -I RH-Firewall-1-INPUT 2 -p tcp -s 0.0.0.0/0 --dport 22 -j DROP
```

Step 4) IPTables의 변경된 정책 저장 및 서비스 재시작

```
$ service iptables save
$ service iptables restart
```

● Nutanix

Step 1) Controller VM에 접속하여 설정 확인

```
sudo cat /etc/hosts.allow | grep -v "^#"
```

Step 2) vi 편집기를 이용하여 hosts.allow 파일에 ssh 접속이 필요한 IP만 접속을 허용 하도록 설정

```
sudo vi /srv/salt/security/CVM/network/hosts.allow
```

```
sshd: 192.168.100.1 : ALLOW
```

Step 3) 변경 설정 적용

```
sudo salt-call state.sls security/CVM/networkCVM
```

HV-03 (상)	가상화 장비 > 1. 계정 관리
	가상화 장비 루트계정 관리
개요	
점검 내용	별도의 관리자 계정을 생성하여 관리 여부 점검
점검 목적	허용한 호스트만 서비스를 사용하게 하여 비인가자의 무단 접근 시도를 예방하기 위함
보안 위협	루트 계정은 누구나 알 수 있는 계정이기 때문에 비인가자의 접속 시도 및 비밀번호 무차별 대입 공격에 노출될 위험이 존재함
참고	※ 무차별 대입 공격(Brute-force Attack): 특정한 암호를 풀기 위해 가능한 모든 값을 대입하는 것
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter
판단 기준	양호 : 별도의 관리자 계정을 생성하여 가상화 장비가 관리된 경우
	취약 : 루트 계정으로 가상화 장비가 관리된 경우
조치 방법	별도의 계정을 생성하여 관리자 권한을 부여하고 루트 계정의 권한은 제거하거나 비활성화
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속

https://<VMware ESXi IP>

Step 2) 호스트 > 작업 > 사용 권한으로 이동

Step 3) root 계정의 관리자 권한이 제거되고 별도의 관리자 권한이 존재하는지 확인

+ 사용자 추가 - 사용자 제거 + 역할 할당	
사용자 ▲ ▼	역할 ▼
dcui	관리자
root	관리자
vpxuser	관리자
3 항목	

[별도의 관리자 권한 확인]

11. 가상화 장비

- Step 4) root 계정 이외에 관리자 권한이 부여된 계정이 없는 경우 별도의 계정 생성
호스트 > 관리 > 보안 및 사용자 > 사용자 추가

[별도의 계정 생성]

- Step 5) 별도로 생성한 계정에 관리자 권한 부여
호스트 > 작업 > 사용 권한 > 사용자 추가

[계정 관리자 권한 부여]

- Step 6) root 계정의 관리자 권한 제거

[root 계정 관리자 권한 제거]

HV-04 (상)	가상화 장비 > 1. 계정 관리
	가상화 장비 계정 권한 관리
개요	
점검 내용	공용 계정 등 불필요한 계정이 존재하는지 여부 점검
점검 목적	사용하지 않는 불필요한 계정을 관리함으로써 관리되지 않는 계정을 통한 비인가자의 무단 접속 또는 공격을 차단하기 위함
보안 위협	시스템에 등록되어 있는 불필요한 계정을 관리하지 않을 경우 비인가자의 무단 접근이 가능하며, 공용 계정 및 퇴사자 계정이 존재할 경우 해당 계정을 통한 침해사고 발생 시 사후 추적이 어려울 수 있는 위험이 존재함
참고	※ 1인 1계정 사용을 원칙으로 운영해야 하며, 공용 계정은 가급적 사용을 지양해야 함
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : 불필요한 공용 계정 및 퇴사자 계정이 존재하지 않은 경우
	취약 : 불필요한 공용 계정 및 퇴사자 계정이 존재하는 경우
조치 방법	불필요한 공용 계정 및 퇴사자 계정 제거
조치 시 영향	애플리케이션에서 사용하는 계정의 경우 삭제 시 서비스 가용성에 영향을 줄 수 있음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

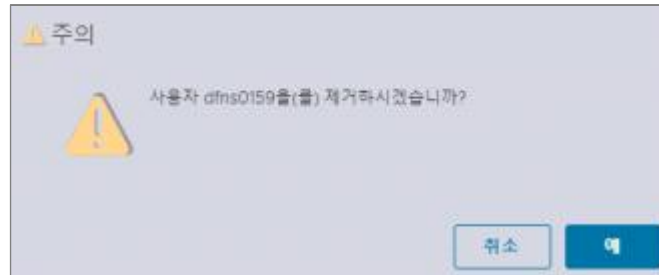
Step 2) 호스트 > 관리 > 보안 및 사용자 > 사용자로 이동

사용자 이름	설명
root	Administrator
user	최고관리자
dfns0159	일반사용자

[등록된 계정 확인]

11. 가상화 장비

Step 3) 불필요한 계정이 존재하는 경우 해당 계정 삭제



[불필요한 계정 제거]

- XenServer, KVM

Step 1) 호스트 접속

Step 2) 등록되어 있는 계정 확인

```
$ grep /bin/bash /etc/passwd | cut -f1 -d:
root
user1
```

Step 3) 불필요한 계정이 존재하는 경우 해당 계정 삭제

```
$ userdel -r <계정명>
```

- Nutanix

Step 1) Nutanix Web 콘솔 페이지 접속

<https://<Nutanix 웹 콘솔 IP>:9440> 접속

Step 2) Settings > Users an Roles > Local User Management를 선택하고 불필요한 계정이 존재하는 경우 해당 계정 삭제

USERNAME	NAME	EMAIL	ROLES	ENABLED	
admin			Cluster Admin, User Admin, Viewer	Yes	✎
user01	test test	test@test.com	Cluster Admin, Viewer	Yes	✎ ✕

HV-05 (상)	가상화 장비 > 1. 계정 관리
	가상화 장비 사용자 인증 강화
개요	
점검 내용	사용자 계정별 적절한 권한이 부여 여부 점검
점검 목적	가상화 시스템에 등록된 계정들에 용도별 권한을 부여함으로써 권한 없는 사용자의 설정 변경으로 인한 시스템 침입 경로 유출 위험을 줄이고 관리자 계정이 아닌 일반 계정이 공격자에게 탈취되었을 때 가상화 시스템을 장악하지 못하도록 하기 위함
보안 위험	가상화 시스템에 등록된 계정이 모두 관리자 권한으로 부여된 경우 권한 없는 사용자의 의도하지 않은 설정 변경을 통하여 공격자에게 가상화 시스템 침입 경로 제공 위험이 존재함
참고	※ 최고 관리자 권한은 최소한의 계정에만 부여
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : 계정별 불필요한 권한이 부여되지 않은 경우
	취약 : 계정별 불필요한 권한이 부여된 경우
조치 방법	불필요한 권한이 부여된 계정에 대한 권한 제거
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 호스트 > 작업 > 사용 권한으로 이동

Step 3) 등록된 계정별 사용 권한 확인

+ 사용자 추가 - 사용자 제거 + 역할 할당	
사용자 ▲	역할 ▼
dcui	관리자
dfns0159	읽기 전용
root	관리자
user	관리자
vpxuser	관리자
5 항목	

[등록된 계정별 사용 권한 확인]

11. 가상화 장비

Step 4) 불필요한 권한이 부여되어 있는 경우 해당 계정 선택

Step 5) 역할에 맞는 권한으로 변경

[계정 권한 변경]

● XenServer

[Active Directory에 가입되어 있지 않은 경우]

Step 1) 호스트에 접속

Step 2) bash 사용자 목록 확인

```
$ grep /bin/bash /etc/passwd | cut -f1 -d:
root
user1
```

Step 3) 불필요한 계정 제거

```
$ gpasswd -d user1 users
```

[Active Directory에 가입되어 있는 경우]

Step 4) 호스트에 접속

Step 5) 계정별 부여된 권한 확인

```
$ xe subject-list
uuid ( RO): bb6dd239-1fa9-a06b-a497-3be28b8dca44
subject-identifier ( RO): S-1-5-21-1539997073-1618981536-2562117463-2244
other-config (MRO): subject-name: example01\user_vm_admin; subject-upn: \
user_vm_admin@XENDT.NET; subject-uid: 1823475908; subject-gid: 1823474177; \
subject-sid: S-1-5-21-1539997073-1618981536-2562117463-2244; subject-gecos: \
user_vm_admin; subject-displayname: user_vm_admin; subject-is-group: false; \
subject-account-disabled: false; subject-account-expired: false; \
subject-account-locked: false; subject-password-expired: false
```

```
roles (SRO): vm-admin
```

... 이하 생략 ...

Step 6) 부적절한 권한이 있는 경우 기존의 역할을 제거하고 새로운 역할을 추가

```
$ xe subject-role-remove uuid=<subject uuid> role-name=<role_name_to_remove>
$ xe subject-role-add uuid=<subject uuid> role-name=<role_name_to_add>
```

● KVM

Step 1) 호스트에 접속

Step 2) bash 계정 목록 확인

```
$ grep /bin/bash /etc/passwd | cut -f1 -d:
root
user1
```

Step 3) 불필요한 계정 제거

```
$ gpasswd -d user1 users
```

● Nutanix

Step 1) 웹 콘솔에 접속하여 등록된 사용자 계정 및 권한 확인

<https://<Nutanix 웹 콘솔 IP>:9440> 접속

Settings > Users an Roles > Local User Management 선택

USERNAME	NAME	EMAIL	ROLES	ENABLED	
admin			Cluster Admin, User Admin, Viewer	Yes	✎
user1	gildong hong	gildong.h@abc.com	Cluster Admin, User Admin, Viewer	Yes	✎ ✕

Step 1) 불필요한 권한이 부여되어 있는 경우 해당 계정 선택

11. 가상화 장비

USERNAME	NAME	EMAIL	ROLES	ENABLED	
admin			Cluster Admin, User Admin, Viewer	Yes	
user1	gildong hong	gildong.h@abc.com	Cluster Admin, User Admin, Viewer	Yes	 

Step 2) 불필요한 권한 제거

Update User

?

Enter the attributes for this user. Passwords must be at least eight characters long. Username is the name that is used by the user to sign into the Nutanix console.

Username

First Name

Last Name

Email

Language

Roles

☐ User Admin ⓘ

☒ Cluster Admin

< Back

Reset Password

Cancel

Save

HV-06 (상)	가상화 장비 > 1. 계정 관리
	비밀번호 관리정책 설정
개요	
점검 내용	로그인 계정에 대한 비밀번호 관리 정책 설정 여부 점검
점검 목적	로그인 계정 비밀번호에 대한 관리 정책 미흡으로 인한 계정 탈취를 방지하기 위함
보안 위협	가상화 시스템에 등록된 계정이 유추하기 쉬운 비밀번호 설정 등 미흡한 비밀번호 관리 정책이 적용되어 있으면 무차별 대입 공격을 통한 계정 탈취로 인한 공격자에게 가상화 시스템 침입 경로 제공 위험이 존재함
참고	※ 정책 기준 : 영문 숫자 특수문자 2개 조합 시 10자리 이상, 3개 조합 시 8자리 이상, 비밀번호 변경 기간 90일 이하
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : 로그인 계정 비밀번호 관리 정책이 적용된 경우
	취약 : 로그인 계정 비밀번호 관리 정책이 적용되지 않은 경우
조치 방법	로그인 계정 비밀번호를 관리 정책에 맞게 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) WEB 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 호스트 > 관리 > 시스템 > 고급 설정으로 이동

Step 3) Security.PasswordQualityControl 설정값 확인



[Security.PasswordQualityControl 설정값 확인]

11. 가상화 장비

Step 4) min = N0, N1, N2, N3, N4 중 N3, N4의 값이 8 미만일 경우 [옵션 편집]을 클릭하여 아래와 같이 수정

[옵션 값 수정]

Step 5) Security.PasswordMaxDays 설정값 확인

[최대 암호 수명 값 확인]

Step 6) 90일 이하로 설정되어 있지 않은 경우 [옵션 편집]을 클릭하여 아래와 같이 수정

[최대 암호 수명 값 90 설정]

※ (예시) retry = M min = N0, N1, N2, N3, N4

- M: 암호 변경 시, 조건을 불만족하는 암호 입력 시 다시 암호를 되묻는 횟수
- N0: 문자 종류(대문자, 소문자, 숫자, 특수문자) 중 한 가지만 사용해 구성된 암호에 허용되는 최소 암호 글자 수
- N1: 문자 종류(대문자, 소문자, 숫자, 특수문자) 중 두 가지를 사용해 구성된 암호에 허용되는 최소 비밀번호 길이
- N2: 암호 문구 사용 시, 허용되는 최소 비밀번호 길이

- N3 : 문자 종류(대문자, 소문자, 숫자, 특수문자) 중 세 가지를 사용해 구성된 암호에 허용되는 최소 비밀번호 길이
- N4 : 문자 종류(대문자, 소문자, 숫자, 특수문자) 중 네 가지를 사용해 구성된 암호에 허용되는 최소 비밀번호 길이

disabled : 길이에 관계 없이 해당 종류의 암호를 사용하지 않음

암호의 첫 문자로 사용되는 대문자와 마지막 문자로 사용되는 숫자는 문자 종류의 수로 포함되지 않음

● VMware vCenter

Step 1) vSphere Client 접속 후, 다음 메뉴에 접근하여 확인(vSphere Client 버전에 따라, 메뉴 명칭은 달라질 수 있음)

Step 2) (vCenter6.5) "관리" > "Single Sign On" > "구성" > "Policies" > "암호 정책" > 비밀번호 정책 확인

Step 3) (vCenter8) "관리" > "Single Sign On" > "구성" > "로컬 계정" > "암호 정책" > 비밀번호 정책 확인

Step 4) 비밀번호 정책 설정 적용

● XenServer

Step 1) XenServer 접속 > Local Command Shell 실행

Step 2) 아래 명령어를 통해 비밀번호 설정 확인

```
# cat /etc/login.defs | grep -i "PASS_MAX_DAYS"
```

```
# cat /etc/login.defs | grep -i "PASS_MIN_DAYS"
```

```
# cat /etc/login.defs | grep -i "PASS_MIN_LEN"
```

Step 3) 아래 명령어 적용

```
# vi /etc/login.defs
```

```
PASS_MIN_LEN 8
```

```
PASS_MAX_DAYS 90
```

```
PASS_MIN_DAYS 7
```

● KVM

[RHEL 8 이후 버전 기반 리눅스]

Step 1) 아래 경로 설정 파일 확인

```
/etc/security/faillock.conf
```

11. 가상화 장비

```
/etc/security/pwquality.conf
```

Step 2) 비밀번호 정책 설정이 되어 있지 않으면 적용 설정

비밀번호 정책 설정 예시(UNIX 기반)

```
예시)password requisite pam_cracklib.so try_first_pass retry=3 minlen=8 lcredit=-1 ucredit=-1 dcredit=-1
ocredit=-1
```

● Nutanix

Step 1) Controllor VM에 접속하여 비밀번호 최소 사용 기간 확인

```
sudo cat /etc/login.defs | grep -v "^#" | grep "PASS_MAX_DAYS"
```

Step 2) Controllor VM에 접속하여 비밀번호 최소 사용 기간을 90일로 설정

```
sudo vi /srv/salt/security/CVM/pamCVM.sls
```

```
passmaxdays:
  file:
    - replace
    - name: /etc/login.defs
    - pattern: '^PASS_MAX_DAYS.*'
    - repl: 'PASS_MAX_DAYS 90'
```

Step 3) 변경된 설정을 /etc/login.defs 파일에 적용

```
sudo salt-call state.sls security/CVM/pamCVM
```

Step 4) checkusergroupsCVM.sls 파일에서 admin, nutanix 계정의 비밀번호 최대 사용기간 설정 변경

```
sudo vi /srv/salt/security/CVM/checkusergroupsCVM.sls
```

```
nutanix:
  user:
    - present
    - shell: /bin/bash
    - home: /home/nutanix
    - uid: 1000
    - gid_from_name: True
    - mindays: 1
    - maxdays: 92

admin:
  user:
    - present
    - shell: /bin/bash
    - home: /home/admin
```

```
- uid: 2000
- gid_from_name: True
- mindays: -1
- maxdays: 92
```

Step 5) 변경한 설정 적용

```
sudo salt-call state.sls security/CVM/checkusergroupsCVM
```

Step 6) Controller VM에 접속하여 비밀번호 최소길이 설정 확인

```
cat /etc/login.defs | grep -v "^#" | grep "PASS_MIN_LEN"
```

Step 7) 비밀번호 최소 길이를 8자리 이상으로 변경

```
sudo vi /srv/salt/security/CVM/pamCVM.sls
```

```
passminlendif:
file:
- replace
- name: /etc/login.defs
- pattern: '^PASS_MIN_LEN.*'
- repl: 'PASS_MIN_LEN 9'
- onlyif:
```

Step 8) 변경한 설정 적용

```
sudo salt-call state.sls security/CVM/pamCVM
```

참고

- ※ 영문, 숫자, 특수문자 2개 조합 시 10자리 이상, 3개 조합 시 8자리 이상 설정 권고
- ※ 비밀번호 최대 사용 기간을 90일(3개월) 이하로 설정할 것을 권고.
- ※ 비밀번호 최소 사용 기간을 7일(1주) 이상으로 설정할 것을 권고.

11. 가상화 장비

HV-07 (상)	가상화 장비 > 1. 계정 관리
	계정 잠금 임계값 설정
개요	
점검 내용	로그인 계정에 대한 비밀번호 관리 정책 설정 여부 점검
점검 목적	잘못된 비밀번호 입력을 제한하지 않으면 무차별 대입 공격을 통한 계정 탈취 위험이 발생할 수 있어 실패 횟수 설정을 통해 가상화 장비 내부 침입을 방지하기 위함
보안 위협	잘못된 비밀번호 입력을 제한하지 않으면 무차별 대입 공격을 통한 계정 탈취로 공격자에게 가상화 시스템 침입 경로 제공 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, KVM
판단 기준	양호 : 로그인 시도 실패 횟수에 따른 계정 잠금 설정이 적용된 경우
	취약 : 로그인 시도 실패 횟수에 따른 계정 잠금 설정이 적용되지 않은 경우
조치 방법	로그인 시도 실패 횟수 제한 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 관리 > 설정 > 시스템 > 고급 설정으로 이동

Step 3) Security.AccountLockFailures 설정이 5 이하로 설정되어 있는지 확인



[계정 잠금 실패 값 확인]

Step 4) 5 이하로 설정되어 있지 않은 경우 [옵션 편집]을 클릭하여 아래와 같이 수정

[계정 잠금 실패 값 설정]

Step 5) Security.AccountUnlockTime 설정이 600초(10분) 이상으로 설정되어 있는지 확인

[계정 잠금 해제 시간 확인]

Step 6) 600초(10분) 이상으로 설정되어 있지 않은 경우 [옵션 편집]을 클릭하여 아래와 같이 수정

[계정 잠금 해제 시간 설정]

※ 시스템이 관련 기능을 지원하지 않을 경우, 내부 정책 확인

11. 가상화 장비

● VMware vCenter

Step 1) vSphere Client 접속 후, 다음 메뉴에 접근하여 확인(vSphere Client 버전에 따라, 메뉴 명칭은 달라질 수 있음)

(vCenter6.5) "관리" > "Single Sign On" > "구성" > "Policies" > "잠금정책(Lockout Policy)" > 접속제한 관련 설정(실패한 최대 로그인 시도 횟수, 실패 시간 간격, 잠금 해제 시간)을 확인

(vCenter8) "관리" > "Single Sign On" > "구성" > "로컬 계정" > "잠금정책(Lockout Policy)" > 접속제한 관련 설정(실패한 최대 로그인 시도 횟수, 실패 시간 간격, 잠금 해제 시간)을 확인

● KVM

Step 1) 예시) RHEL 8 이후 버전 기반 리눅스

아래 경로 설정 파일 확인

`/etc/security/faillock.conf`

`/etc/security/pwquality.conf`

Step 2) 비밀번호 정책 설정이 되어있지 않으면 적용 설정

비밀번호 정책 설정 예시

`# vi /etc/pam.d/system-auth`

`auth required /lib/security/pam_tally.so deny=5 unlock_time=120`

`no_magic_root`

`account required /lib/security/pam_tally.so no_magic_root reset`

HV-08 (중)	가상화 장비 > 2. 시스템 서비스 관리
	시스템 사용 주의사항 출력 설정
개요	
점검 내용	원격 로그인 시 시스템 사용 주의사항 출력 여부 점검
점검 목적	원격 로그인 시 시스템 사용 주의사항을 안내해 사용자가 시스템에 접근 시 보안 정책을 인식하도록 하기 위함
보안 위협	사용자가 시스템에 접근 시 보안 정책을 인식하지 못해 인위적인 공격 또는 데이터 유출 등의 보안 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : 시스템 사용 주의사항이 출력된 경우
	취약 : 시스템 사용 주의사항 미출력 또는 표시 문구 내에 시스템 버전 정보가 노출된 경우
조치 방법	시스템 사용 주의사항 출력 설정
조치 시 영향	일반적 경우 해당 없음

점검 및 조치 사례

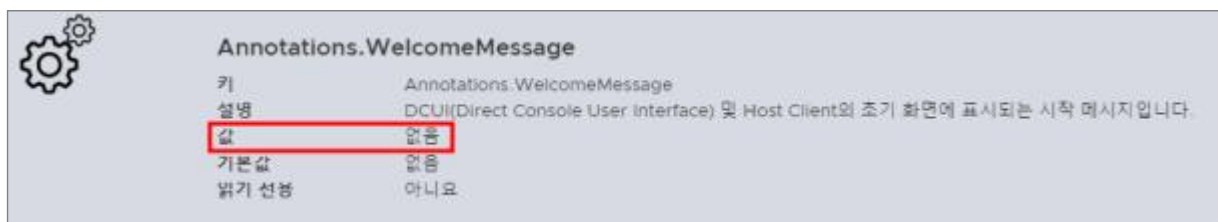
● VMware ESXi

Step 1) Web 콘솔 페이지 접속

https://<VMware ESXi IP>

Step 2) 호스트 > 관리 > 시스템 > 고급 설정으로 이동

Step 3) Annotations.WelcomeMessage 설정 값 확인



[시스템 사용 주의사항 출력 값 확인]

Step 4) 시스템 사용 주의사항 문구가 설정되어 있지 않은 경우 [옵션 편집]을 클릭하여 문구 입력

11. 가상화 장비

- 다음의 파일들에 메시지 설정 존재 여부 확인

1. /etc/motd 에 시스템 사용 주의사항 설정
2. /etc/issue 파일에 로그인 경고 메시지 설정
3. /etc/ssh/sshd_config 배너 값 설정

● VMware vCenter

Step 1) vSphere Client 접속 후, 다음 메뉴에 접근하여 확인(vSphere Client 버전에 따라, 메뉴 명칭은 달라질 수 있음)

(vCenter6.5) "관리" > "Single Sign On" > "구성" > "로그인 배너" > 로그인 배너 설정 여부를 확인

(vCenter8) "관리" > "Single Sign On" > "구성" > "로그인 메시지" > 로그인 배너 설정 여부를 확인

● KVM

Step 1) 배너 설정 여부 확인

```
# cat /etc/ssh/sshd_config | grep "Banner"
```

Step 2) /etc/ssh/sshd_config 파일에 배너 내용 삽입

```
# vi /etc/ssh/sshd_config
```

```
Banner /etc/issue.net
```

(예시) This system is for the use of authorized users only.

● XenServer

Step 1) 배너 설정 여부 확인

```
# cat /etc/ssh/sshd_config | grep "Banner"
```

Step 2) /etc/ssh/sshd_config 파일에 배너 내용 삽입

```
# vi /etc/ssh/sshd_config
```

```
Banner /etc/issue.net
```

(예시) This system is for the use of authorized users only.

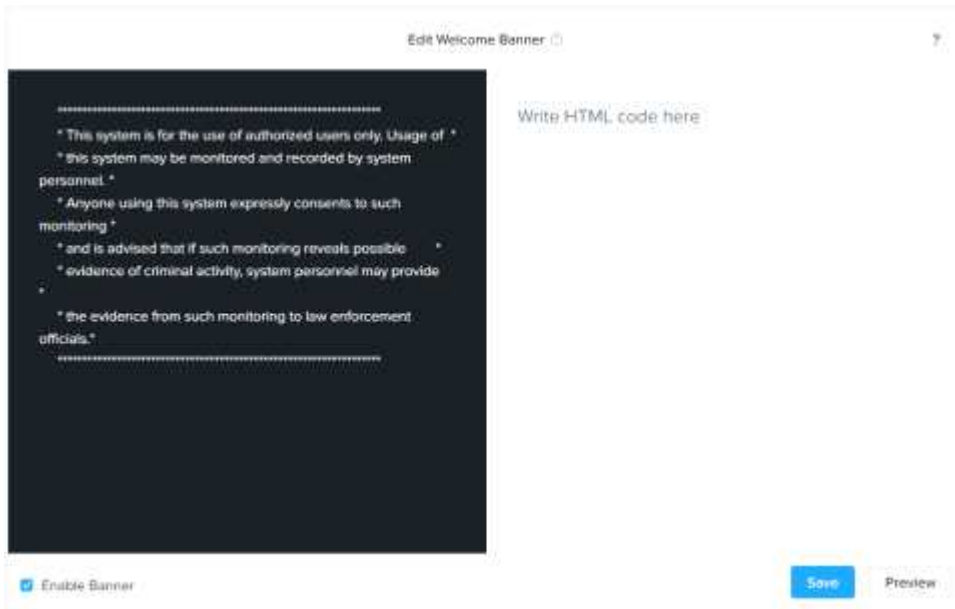
● Nutanix

[관리 웹 콘솔 배너 설정]

Step 1) 웹 콘솔에 접속

https://<Nutanix 관리 Web IP>:9440 접속

Step 2) Settings > Apperance > Welcome Banner 메뉴 선택 > 배너 입력 > Enable Banner 체크 > Save 버튼 클릭



[SSH 배너 설정]

■ SSH 설정 파일 직접 변경

Step 1) AHV, Controller VM에 각각 SSH 접속

Step 2) 배너 파일 내용 입력

```
sudo vi /etc/issue
```

Step 3) ssh 설정 파일에서 배너 파일 경로 설정

```
sudo vi /etc/ssh/sshd_config
```

```
Banner /etc/issue
```

Step 4) ssh 데몬 재시작

```
systemctl restart sshd
```

■ DoD 배너 설정

Step 1) Controller VM 접속하여 DoD 배너 비활성화

```
ncli cluster edit-hypervisor-security-params enable-banner=false
```

```
nutanix@cvm$ ncli cluster edit-cvm-security-params enable-banner=false
```

Step 2) AHV 접속하여 DoD 배너 파일 백업

```
[root@AHV-host ~]# cp -a /etc/puppet/modules/kvm/files/issue.DoD \
/etc/puppet/modules/kvm/files/issue.DoD.bak
```

11. 가상화 장비

Step 3) AHV의 DoD 배너 파일 수정

```
[root@AHV-host ~]# vi /etc/issue.DoD
```

Step 4) Controller VM의 DoD 배너 파일 백업

```
nutanix@cvm$ sudo cp -a /srv/salt/security/CVM/sshd/DODbanner \
/srv/salt/security/CVM/sshd/DODbannerbak
```

Step 5) Controller VM의 DoD 배너 파일 수정

```
nutanix@cvm$ sudo vi /srv/salt/security/CVM/sshd/DODbanner
```

Step 6) AHV 및 Controller VM의 DoD 배너 활성화

```
nutanix@cvm$ ncli cluster edit-hypervisor-security-params enable-banner=true
nutanix@cvm$ ncli cluster edit-cvm-security-params enable-banner=true
```

HV-09 (증)	가상화 장비 > 2. 시스템 서비스 관리
	NTP 및 시각 동기화 설정
개요	
점검 내용	NTP 설정을 통한 시간 동기화 여부 점검
점검 목적	시스템이 NTP를 통한 시간 동기화를 적용해 가상화 장비 침해, 장애 등의 위협 발생 시 원활한 로그 분석 수행이 가능하도록 하기 위함
보안 위협	시스템이 NTP를 통한 시간 동기화가 되지 않을 경우 가상화 장비 침해, 장애 등의 위협 발생 시 로그 분석을 통한 침입 경로 파악이 어려워 초기 대응 불가 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : NTP서버와 시간 동기화 설정을 적용한 경우
	취약 : NTP 서버와 시간 동기화 설정을 적용하지 않은 경우
조치 방법	NTP 설정 및 시각 동기화 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 호스트 > 관리 > 시스템 > 시간 및 날짜로 이동

Step 3) NTP 설정 확인



[NTP 설정 확인]

11. 가상화 장비

Step 4) NTP 서버가 설정되어 있지 않은 경우, [NTP 설정 편집]을 클릭하여 NTP 서버 정보 입력

[NTP 클라이언트 사용 설정]

● VMware vCenter

Step 1) vCenter Server 관리 페이지(<https://<주소>:5480/>) 접속 후, 다음 메뉴에 접근하여 확인(vCenter 버전에 따라, 메뉴 명칭은 달라질 수 있음)

"시간" > "시간 동기화" > NTP 설정 여부를 확인

● KVM

Step 1) PHC 사용 여부 확인

Step 2) 사용하지 않으면 활성화 적용

```
# echo ptp_kvm > /etc/modules-load.d/ptp_kvm.conf
```

Step 3) /dev/ptp0 시계를 chrony 구성에 대한 참조로 추가 설정

```
# echo "refclock PHC /dev/ptp0 poll 2" >> /etc/chrony.conf
```

Step 4) chrony 데몬 다시 시작

```
# systemctl restart chronyd
```

● XenServer

Step 1) XenServer 접속 > Network and Management Interface > Network Time (NTP) > Provide NTP Servers Manually > 별도 NTP 서버 지정 설정 적용

● Nutanix

Step 1) 웹 콘솔에 접속

https://<Nutanix 웹 콘솔 IP:9440>

Step 2) Settings > NTP Servers 선택하여 NTP 서버가 설정되어 있는지 확인

Step 3) 설정되어 있지 않은 경우 NTP 서버를 입력하고 Add 버튼을 클릭

Step 4) Controller VM에 접속하여 타임존 설정

```
ncli cluster set-timezone timezone="Asia/Seoul"
```

Step 5) Controller VM에 접속하여 Nutanix 호스트 타임존 설정

```
hostssh "date; mv /etc/localtime /etc/localtime.bak; ln -s /usr/share/zoneinfo/Asia/Seoul /etc/localtime; date"
```

※ Nutanix를 처음 설치하면 타임존이 UTC로 설정되어 있어 실제 시간과 차이가 발생

11. 가상화 장비

HV-10 (중)	가상화 장비 > 2. 시스템 서비스 관리
	SNMP Community String 복잡성 적용
개요	
점검 내용	SNMP Community String 복잡성 적용 여부 점검
점검 목적	SNMP Community String이 유추하기 어려운 문자열로 구성해 비인가자가 SNMP 서비스 무단 접근을 방지하기 위함
보안 위협	SNMP Community String이 유추하기 쉬운 문자열로 구성되어 있는 경우 비인가자가 SNMP 서비스에 무단 접근이 가능한 위험이 존재함
참고	※ SNMP v3 사용 우선 권고
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : SNMP Community String이 복잡도를 만족하는 경우
	취약 : SNMP Community String이 복잡도를 만족하지 않는 경우
조치 방법	SNMP Community String을 복잡도를 만족하는 값으로 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) SSH를 통해 ESXi 호스트 서버 접속 후, 다음 명령어 실행

```
$ esxcli system snmp get
```

Step 2) 다음 명령어를 사용해 Community String 값 설정 변경

```
$ esxcli system snmp set --communities <변경 값>
```

● VMware vCenter

Step 1) SNMP 사용 확인

```
if [[ $(vim-cmd proxysvc/service_list | grep 'TSM') ]]; then
echo "SNMP service is running on vcenter"
else
echo "SNMP service is not running on vcenter"
fi
```

```
cat /etc/vmware/snmp.xml | grep community | awk -F '""' '{print $4}'
```

Step 2) SNMP Community String 설정 확인

```
# /etc/snmpd.conf 파일에서 Community String 확인
```

```
# /usr/lib/vmware/vm-support/bin/nvpsvc -printconfig | grep -E "SNMPCommunityString|SNMPAccessControl"
```

● KVM

Step 1) SNMP 파일에서 Community String 값 확인

```
sudo vi /etc/snmp/snmpd.conf
```

Step 2) Community String 설정 후 snmp 서비스 재시작

```
sudo systemctl enable snmpd
```

```
sudo systemctl start snmpd
```

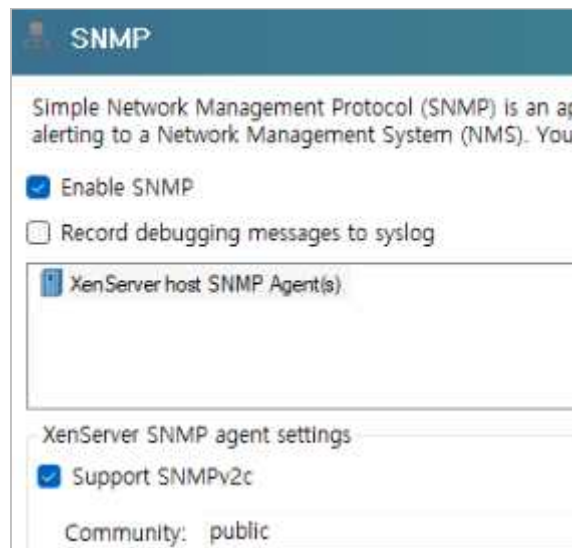
● XenServer

Step 1) XenCenter 접속

Step 2) 해당 서버 설정 > SNMP

Step 3) SNMP 활성화 여부 확인

Step 4) 활성화 또는 필요에 의해 사용 시 Community String 값 확인



[SNMP Community String 값 확인]

● Nutanix

11. 가상화 장비

[불필요한 경우 SNMP 서비스 비활성화]

Step 1) Nutanix 관리 웹 콘솔 접속

<https://<Nutanix 웹 콘솔>:9440>

Step 2) Settings > SNMP 선택

Step 3) Enable for Nutanix objects 체크 해제



SNMP Configuration

Configure SNMP for the Nutanix software.

☐ Enable for Nutanix objects

[SNMP Trap 설정이 필요한 경우 v3 사용]

Step 1) Nutanix 관리 웹 콘솔 접속

<https://<Nutanix 웹 콘솔>:9440>

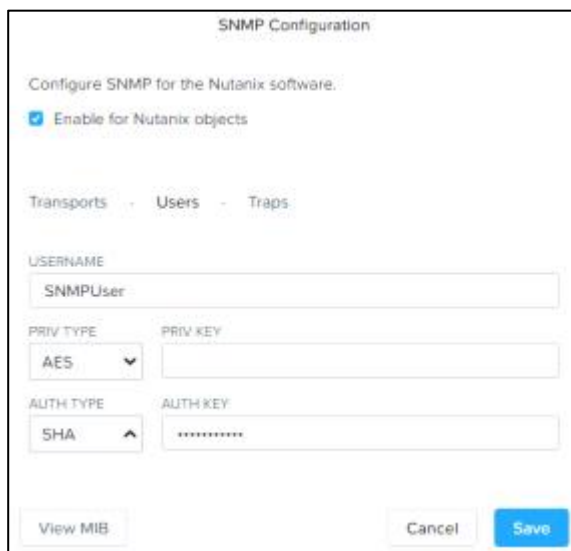
Step 2) Settings > SNMP > Users > New User 클릭



Transports · Users · Traps

+ New User

Step 3) SNMP User 생성



SNMP Configuration

Configure SNMP for the Nutanix software.

☒ Enable for Nutanix objects

Transports · Users · Traps

USERNAME
SNMPUser

PRIV TYPE: AES
PRIV KEY:

AUTH TYPE: SHA
AUTH KEY:

View MIB Cancel Save

Step 4) Traps > New Trap receiver 클릭

SNMP Configuration

Configure SNMP for the Nutanix software:

☒ Enable for Nutanix objects

Transports · Users · **Traps**

+ New Trap Receiver Test all

No Traps Found.

View MIB

Step 5) Receiver Name 및 Trap 수신 IP 설정

SNMP Configuration

RECEIVER NAME
NMS

SNMP VERSION
☐ v2c
☒ v3

TRAP USERNAME
SNMPUser

ADDRESS
192.168.100.222

PORT
162

ENGINE ID

INFORM
False

TRANSPORT PROTOCOL
UDP

View MIB Cancel Save

[v2c를 사용해야 하는 경우 Community String 복잡도 설정]

11. 가상화 장비

Step 1) Nutanix 관리 웹 콘솔 접속

<https://<Nutanix 웹 콘솔>:9440>

Step 2) Settings > SNMP > Traps > 편집 버튼

Step 3) SNMP Community String이 복잡도를 만족하도록 설정

COMMUNITY
Tltjfl35&()

HV-11 (상)	가상화 장비 > 2. 시스템 서비스 관리
	MOB(Managed Object Browser) 서비스 비활성화
개요	
점검 내용	MOB 서비스 비활성화 여부 점검
점검 목적	MOB(Managed Object Browser) 서비스를 통해 시스템 정보 수집, 가상 머신 제어, 시스템 설정 변경 등의 기능이 존재해 비인가자가 해당 기능을 사용하지 못하게 하기 위함
보안 위협	MOB(Managed Object Browser) 서비스가 활성화되어 있을 경우, 해당 인터페이스를 통해 시스템 정보 수집, 가상 머신 제어, 시스템 설정 변경 등의 위험이 존재함
참고	※ ESXi의 경우 기본적으로 비활성화 ※ vCenter의 경우 기본적으로 활성화
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter
판단 기준	양호 : MOB(Managed Object Browser)가 비활성화된 경우
	취약 : MOB(Managed Object Browser)가 활성화된 경우
조치 방법	MOB(Managed Object Browser)서비스 비활성화 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

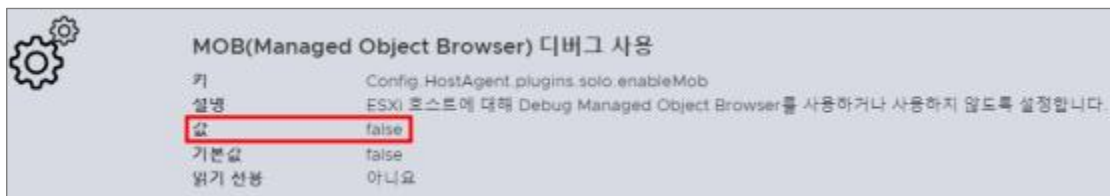
● VMware ESXi

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 호스트 > 관리 > 시스템 > 고급 설정으로 이동

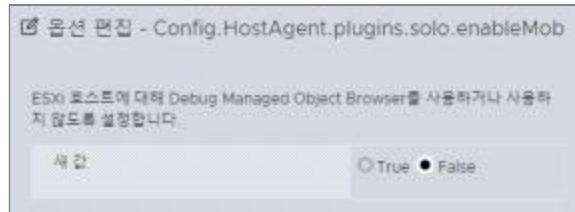
Step 3) Config.HostAgent.plugins.solo.enableMob 설정값 확인



[MOB 활성화 값 확인]

11. 가상화 장비

Step 4) 활성화(true)되어 있을 시, 해당 값을 false로 설정



[MOB 비활성화 설정 적용]

● VMware vCenter

Step 1) vSphere Client 접속 후, 다음 메뉴에 접근하여 확인(vSphere Client 버전에 따라, 메뉴 명칭은 달라질 수 있음)

(vCenter6.5) "호스트 및 클러스터" > [vCenter 서버] > "구성" > "설정" > "고급 설정" > "config.vpxd.enableDebugBrowse" 확인

(vCenter8) "호스트 및 클러스터" > [vCenter 서버] > "구성" > "설정" > "고급 설정" > "config.vpxd.enableDebugBrowse" 확인

HV-12 (상)	가상화 장비 > 2. 시스템 서비스 관리
	ESXi Shell 비활성화
개요	
점검 내용	ESXi Shell(TSM, TSM-SSH) 비활성화 여부 점검
점검 목적	감사기록에 대한 관리에 어려움이 발생할 수 있는 ESXi Shell(TSM, TSM-SSH) 사용 행위를 방지해 플랫폼(vCenter)과 동기화하기 위함
보안 위협	ESXi Shell(TSM, TSM-SSH)에서 이루어지는 행위는 관리 플랫폼(vCenter)과 동기화되지 않을 수 있어 감사기록 관리가 불가능해지는 위험이 존재함
참고	※ TSM(Tech Support Mode): 문제 해결 및 진단을 위해 ESXi 호스트에 물리적으로 접근하여 사용할 수 있는 텍스트 기반 명령 인터페이스 ※ TSM-SSH(Tech Support Mode via SSH): SSH 프로토콜을 통해 원격에서 TSM의 기능을 사용할 수 있게 하는 서비스
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : ESXi Shell(TSM, TSM-SSH) 서비스가 비활성화된 경우
	취약 : ESXi Shell(TSM, TSM-SSH) 서비스가 활성화된 경우
조치 방법	ESXi Shell(TSM, TSM-SSH) 서비스가 비활성화 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 호스트 > 관리 > 서비스로 이동

Step 3) TSM, TSM-SSH 서비스 활성화 여부 확인



[TSM TSM-SSH 서비스 활성화 여부 확인]

Step 4) TSM, TSM-SSH 서비스가 활성화되어 있는 경우, [중지] 클릭하여 서비스 중지

11. 가상화 장비

HV-13 (상)	가상화 장비 > 2. 시스템 서비스 관리
	ESXi Shell 세션 종료 시간 설정
개요	
점검 내용	ESXi Shell(TSM, TSM-SSH)의 Session Timeout(로그인 후 일정 시간 사용하지 않을 경우 세션 종료) 설정의 적정성 여부 점검
점검 목적	비인가자에 의한 시스템 무단 사용 방지 목적으로 Session Timeout 설정을 적용하기 위함
보안 위협	ESXi Shell(TSM, TSM-SSH)의 Session Timeout(로그인 후 일정 시간 사용하지 않을 경우 세션 종료) 설정이 적용되어 있지 않으면, 비인가자에 의한 시스템 무단 사용 위험이 존재함
참고	※ TSM(Tech Support Mode) : 문제 해결 및 진단을 위해 ESXi 호스트에 물리적으로 접근하여 사용할 수 있는 텍스트 기반 명령 인터페이스 ※ TSM-SSH(Tech Support Mode via SSH) : SSH 프로토콜을 통해 원격에서 TSM의 기능을 사용할 수 있게 하는 서비스 ※ 기본값 : 0(제한 없음) ※ 기본적으로 ESXi Shell은 비활성화(HV-12)하여야 하며, 해당 설정은 필요 시 ESXi Shell을 사용할 경우에 대비한 설정
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : Session Timeout 값(ESXiShellInteractiveTimeOut)이 600 이하로 설정된 경우
	취약 : Session Timeout 값(ESXiShellInteractiveTimeOut)이 0이거나, 600초과로 설정된 경우
조치 방법	Session Timeout 값(ESXiShellInteractiveTimeOut)이 900 이하 설정
조치 시 영향	일반적 경우 영향 없음

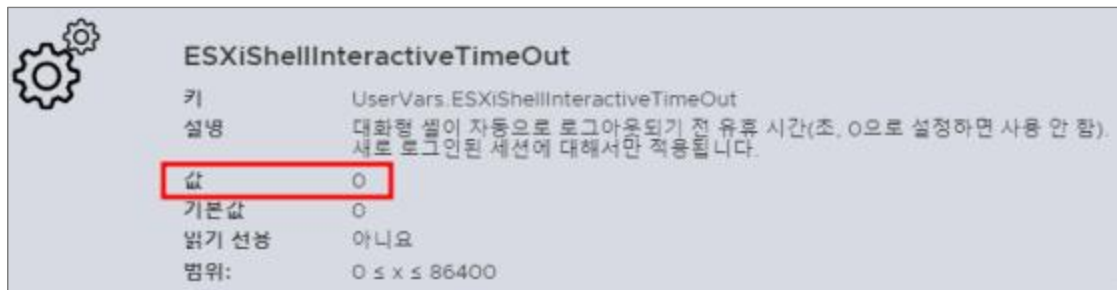
점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 관리 > 설정 > 시스템 > 고급 설정으로 이동

Step 3) UserVars.ESXiShellInteractiveTimeOut 설정값 확인



ESXiShellInteractiveTimeout

키: UserVars.ESXiShellInteractiveTimeout

설명: 대화형 셸이 자동으로 로그아웃되기 전 유휴 시간(초, 0으로 설정하면 사용 안 함). 새로 로그인된 세션에 대해서만 적용됩니다.

값: 0

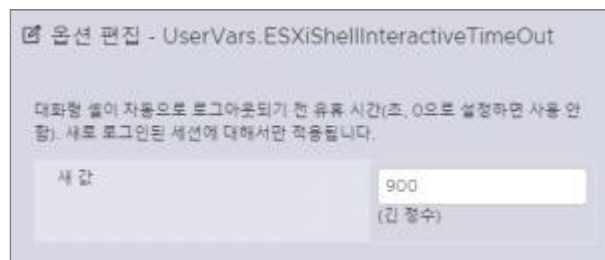
기본값: 0

읽기 전용: 아니요

범위: $0 \leq x \leq 86400$

[ESXiShellInteractiveTimeout 설정값 확인]

Step 4) 0 또는 600초(10분) 초과로 설정되어 있을 경우 [옵션 편집]을 클릭하여 아래와 같이 수정



☒ 옵션 편집 - UserVars.ESXiShellInteractiveTimeout

대화형 셸이 자동으로 로그아웃되기 전 유휴 시간(초, 0으로 설정하면 사용 안 함). 새로 로그인된 세션에 대해서만 적용됩니다.

새 값: 900
(간 정수)

[900 이하 설정 적용]

11. 가상화 장비

HV-14 (중)	가상화 장비 > 2. 시스템 서비스 관리
	원격 로그 서버 이용
개요	
점검 내용	원격 로그 서버를 이용한 로그 저장 여부 점검
점검 목적	원격 로그 서버를 이용하여 로그 관리를 수행하여 시스템 가용성 저하, 침해에 따른 로그 유실을 방지하기 위함
보안 위협	원격 로그 서버를 이용하여 로그 관리를 하지 않을 경우, 시스템 가용성 저하, 침해에 따른 로그 유실 등의 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, XenServer, KVM, Nutanix
판단 기준	양호 : 원격 로그 서버 또는 스토리지가 연동 설정된 경우
	취약 : 원격 로그 서버 또는 스토리지가 연동 설정되지 않은 경우
조치 방법	원격 로그 서버 또는 스토리지 연동 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 호스트 > 관리 > 시스템 > 고급 설정으로 이동

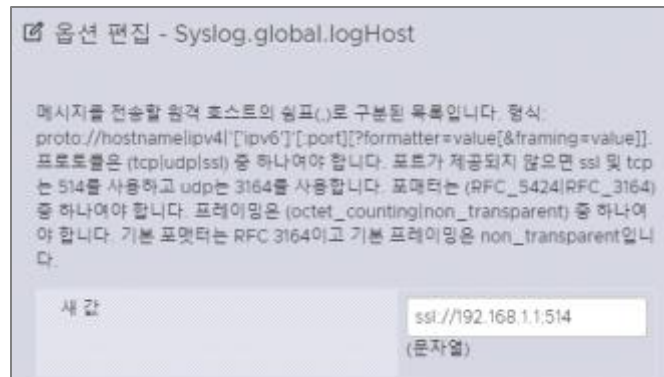
Step 3) Syslog.global.logHost 설정값 확인



[Syslog.global.logHost 설정 값 확인]

Step 4) [옵션 편집]을 클릭한 후 아래와 같은 양식으로 원격 로그 서버 또는 스토리지 입력

protocol://hostname|ipv4|['ipv6'][:port]



[Syslog.global.logHost 설정]

※ syslog 설정 예시

예시	설명
tcp://10.0.1.10:3555	TCP 및 Port 3555를 사용하여 Syslog 메시지를 10.0.1.10으로 전송
tcp://[2001:db8:85a3:8d3:1319:8a2e:370:7348]	TCP 및 Port 1514를 사용하여 Syslog 메시지를 IPv6 주소로 전송
udp://10.0.1.10	UDP 및 Port 514를 사용하여 Syslog 메시지를 10.0.1.10으로 전송
ssl://syslog.com	SSL(TLS) 및 Port 514를 사용하여 Syslog 메시지를 syslog.com으로 전송

11. 가상화 장비

● VMware vCenter

Step 1) Syslog 설정 여부를 확인

Step 2) vCenter Server 관리 페이지(<https://<주소>:5480/>) 접속 후, 다음 메뉴에 접근하여 확인(vCenter 버전에 따라, 메뉴 명칭은 달라질 수 있음)

"Syslog" > Syslog 설정 여부를 확인

● KVM

Step 1) 원격 로그 서버 사용 확인

Step 2) (호스트 서버) /etc/rsyslog.conf 파일 확인

Step 3) 원격 로그 서버 전송 지시어 확인

Step 4) logger 명령어를 통해 전송 여부 확인

● XenServer

Step 1) Remote Log 서버 사용 유무 확인

Step 2) udp514 Port 확인

netstat -an | grep "udp" 또는 # netstat -an | grep "udp" | egrep "514"

Step 3) Syslog.conf 파일 수정("/etc/sysconfig/syslog" 파일에 "SYSLOGD_OPTIONS"의 "-r" 옵션 삭제)

vi /etc/sysconfig/syslog SYSLOGD_OPTIONS="-m 0"

● Nutanix

Step 1) Controller VM에 접속하여 원격 로깅 서버가 설정되어 있는지 확인

ncli rsyslog-config list

RSyslog Status	: Enabled
RSyslog Servers	: 1
Name	: logcenter
IP Address	: 192.168.100.33
Port	: 514
Protocol	: TCP
Relp Enabled	: false

Step 2) 원격 로깅 서버가 설정되어 있지 않으면 설정 적용

ncli rsyslog-config add-server name=<alias of log server> ip-address=<원격 로그 서버 IP> port=<원격 로

그 서버 포트> network-protocol=tcp relp-enabled=no

Step 3) 로그 레벨 설정

```
ncli rsyslog-config add-module module-name=syslog_module level=info server-name=<alias of log server>
```

11. 가상화 장비

HV-15 (상)	가상화 장비 > 2. 시스템 서비스 관리
	시스템 주요 이벤트 로그 설정
개요	
점검 내용	시스템 주요 이벤트 로그가 설정 여부 점검
점검 목적	시스템 주요 이벤트 로그를 설정해 시스템 문제 발생 시 보안, 성능 등의 이슈를 파악하기 위함
보안 위협	시스템 주요 이벤트 로그가 설정되어 있지 않으면 시스템 문제 발생 시 보안, 성능 등의 이슈를 파악할 수 없는 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	VMware ESXi, vCenter, KVM
판단 기준	양호 : 로그 기록 정책이 내부 정책에 부합하게 설정된 경우
	취약 : 로그 기록 정책이 내부 정책에 부합하게 설정되지 않은 경우
조치 방법	로그 기록 정책을 내부 정책에 부합하게 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 호스트 > 관리 > 시스템 > 고급 설정으로 이동

Step 3) Config.HostAgent.log.level 설정값 확인



[Config.HostAgent.log.level 설정값 확인]

Step 4) 로그 기록 정책 확인 후, [옵션 편집]을 클릭해 내부 정책에 맞게 설정



[Config.HostAgent.log.level 설정 적용]

※ log.level 설정값

로깅 수준	설명
None	로그 기록하지 않음
Quiet	최소한의 로그 항목을 기록함
Panic	패닉 로그(장애 발생 시 기록되는 메시지) 항목만 기록함
Error	패닉 및 에러 로그 항목만 기록함
Warning	패닉, 에러 및 경고 로그 항목만 기록함
Information	패닉, 에러, 경고 및 정보 로그 항목을 기록함
Verbose	패닉, 에러, 경고, 정보 및 세부 정보를 표시하는 로그 항목을 기록함
Trivia	패닉, 에러, 경고, 정보, 세부 정보 표시 및 기타 정보를 표시하는 로그 항목을 기록함

● VMware vCenter

Step 1) 로그 설정 레벨 확인

Step 2) vSphere Client 접속 후, 다음 메뉴에 접근하여 확인(vSphere Client 버전에 따라, 메뉴 명칭은 달라질 수 있음)

(vCenter6.5) "호스트 및 클러스터" > [vCenter 서버] > "구성" > "설정" > "고급 설정" > "config.log.level" 확인

(vCenter8) "호스트 및 클러스터" > [vCenter 서버] > "구성" > "설정" > "고급 설정" > "config.log.level" 확인

11. 가상화 장비

● KVM

Step 1) 호스트에 접속

Step 2) libvirt 설정파일을 확인하여 로그 레벨 확인

```
$ cat /etc/libvirt/libvirtd.conf
```

Step 3) libvirt 설정파일의 log_level 설정 구문 수정

```
$ log_level =
```

Step 4) 변경 사항 적용을 위해 libvirt 데몬 재시작

```
$ systemctl restart libvirtd.service
```

※ log.level 설정값

레벨	로깅 수준	설명
4	ERROR	오류 메시지만 기록함
3	WARNING	경고 및 오류를 기록함
2	INFO	디버그 항목이 아닌 모든 항목을 기록함
1	DEBUG	디버그 항목 및 모든 항목을 기록함

HV-16 (상)	가상화 장비 > 2. 시스템 서비스 관리
	비휘발성 경로 내 로그 파일 저장
개요	
점검 내용	비휘발성 경로에 로그파일 저장 여부 점검
점검 목적	비휘발성 경로에 로그파일 저장하여 로그 상실을 방지하기 위함
보안 위협	휘발성 경로에 로그 파일이 저장될 경우, 일정시간이 지나거나 시스템 재시작 시 저장된 로그를 상실해 로그 분석이 불가능해지는 위험이 존재함
참고	※ ESXi의 경우 기본적으로 /scratch 경로에 로그가 저장되며, 해당 로그는 시스템 재시작 시 또는 하루가 지나면 삭제 ※ 원격 로그 서버 이용(HV-14) 시에도 일부 시스템 로그(vmksummary.log, dvs.log, vmkwarning.log, fdm.log 등)는 전달되지 않으므로 비휘발성 경로에 로그파일 저장 필요 ※ 휘발성 경로 : /scratch/, /tmp, /var/tmp, /run, /dev/shm, /dev/pts 등
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : 로그 파일 경로가 존재하며, 해당 경로가 비휘발성 경로에 저장된 경우
	취약 : 로그 파일 경로가 존재하지 않거나, 휘발성 경로에 저장되지 않은 경우
조치 방법	로그 파일 경로를 비휘발성 로그 파일 경로로 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 호스트 > 관리 > 시스템 > 고급 설정으로 이동

Step 3) Syslog.global.LogDir 설정값 확인



[Syslog.global.LogDir 설정값 확인]

Step 4) 로그 파일 저장 경로 확인 후, [옵션 편집]을 클릭하여 수정

11. 가상화 장비

HV-17 (상)	가상화 장비 > 3. 가상머신 관리
	코어덤프 수집 기능 활성화
개요	
점검 내용	코어 덤프 수집 기능 활성화 여부 점검
점검 목적	코어 덤프 기능이 활성화하여 시스템 장애 발생에 대한 원인을 파악하기 위함
보안 위협	코어 덤프 기능이 활성화되어 있지 않을 경우, 시스템 장애 발생에 대한 원인을 파악할 수 없는 위험이 존재함
참고	※ 코어 덤프 기능(Vmware vSphere Network Dump Collector 서비스): 시스템에서 심각한 오류 발생 시 VMKernel 메모리 상태를 서버로 전송
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : 코어 덤프 수집 기능이 활성화(true)된 경우
	취약 : 코어 덤프 수집 기능이 비활성화(false)된 경우
조치 방법	코어 덤프 수집 기능 활성화 적용
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) SSH를 통해 ESXi 호스트 서버 접속 후, 다음 명령어 실행

```
$ esxcli system coredump network get
```

Step 2) 다음 명령어를 사용해 VMkernel 네트워크 인터페이스와 원격 네트워크 코어 덤프 서버의 IP주소 및 UDP Port 번호 지정

```
$ esxcli system coredump network set --interface-name <VMkernel 인터페이스명> --server-ipv4 <IP주소> --server-port <Port 번호>
```

예시) esxcli system coredump network set --interface-name vmk0 --server-ipv4 10.0.1.10 --server-port 6500

Step 3) 다음 명령어를 사용해 네트워크 코어 덤프 구성 활성화

```
$ esxcli system coredump network set --enable true
```

Step 4) 코어 덤프 수집 기능 활성화 여부 확인

```
$ esxcli system coredump network check
```

HV-18 (상)	가상화 장비 > 3. 가상머신 관리
	가상머신의 장치 변경 제한 설정
개요	
점검 내용	가상 머신 장치 변경 제한 설정 적용 여부 점검
점검 목적	가상 머신(게스트 OS)에서 관리자 권한이 없는 사용자(또는 프로세스)에 의한 장치(네트워크 어댑터, CD-ROM 등) 연결을 끊거나, 설정 변경을 방지하기 위함
보안 위협	가상 머신(게스트 OS)에서 관리자 권한이 없는 사용자(또는 프로세스)에 의한 장치(네트워크 어댑터, CD-ROM 등) 연결을 끊거나, 설정 변경이 가능한 위험이 존재함
참고	※ 서버보안 솔루션 등에서 해당 기능을 통제할 경우 양호
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : 가상 머신의 장치 설정 변경 방지 설정이 활성화(true)된 경우
	취약 : 가상 머신의 장치 설정 변경 방지 설정이 없거나, 비활성화(false)된 경우
조치 방법	가상 머신의 장치 설정 변경 방지 활성화 적용
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 가상 시스템 > [가상 머신 선택] > 설정 편집 > VM 옵션 > 고급 > 구성 매개 변수로 이동

Step 3) isolation.device.edit.disable, isolation.device.connectable.disable 설정값 확인

HV-19 (상)	가상화 장비 > 3. 가상머신 관리
	가상 머신의 불필요한 장치 제거
개요	
점검 내용	불필요한 장치(USB, CD/DVD, 플로피 디스크, 병렬 포트, 직렬 포트) 제거 여부 점검
점검 목적	불필요하게 연결된 외부 장치를 통한 잠재적인 공격 루트로 활용되는 것을 방지하기 위함
보안 위험	불필요하게 연결된 외부 장치는 잠재적인 공격 루트로 활용될 수 있는 위험이 존재함
참고	※ 장치 : USB, CD/DVD, 플로피 디스크, 병렬 포트, 직렬 포트
점검 대상 및 판단 기준	
대상	VMware ESXi, XenServer
판단 기준	양호 : 불필요한 장치가 가상 머신에 연결되지 않은 경우
	취약 : 불필요한 장치가 가상 머신에 연결된 경우
조치 방법	불필요한 장치 연결 해제 적용
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

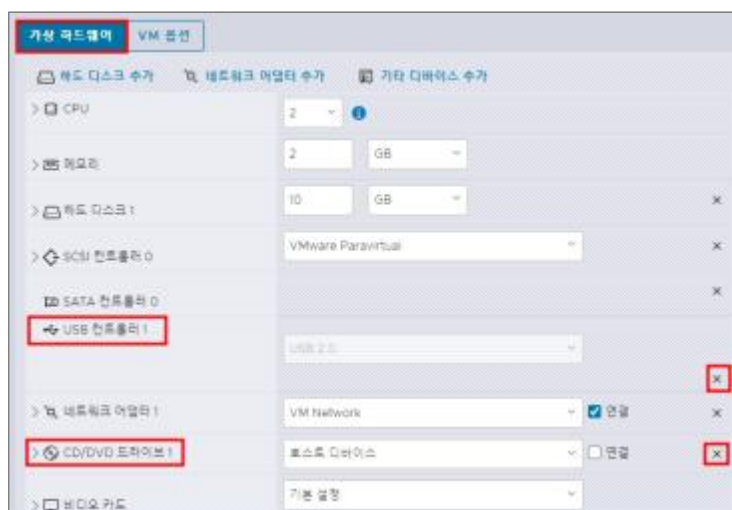
● VMware ESXi

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 가상 시스템 > [가상 머신 선택] > 설정 편집 > 가상 하드웨어로 이동

Step 3) 장치 연결상태 확인 및 불필요한 외부 장치 비활성화



[장치 연결상태 확인]

● XenServer

Step 1) 장치 연결상태 확인

1. PCI 장치 목록 확인

`lspci`

2. 블록 디바이스 목록 확인

`lsblk`

3. 네트워크 인터페이스 확인

`ifconfig` 또는 `ip addr`

4. 가상 머신의 디스크 목록 확인

`xe vm-list name-label="<VM_NAME>"`

5. VM에 연결된 디스크 확인

`xe vbd-list vm-uuid=<VM_UUID>`

6. 모든 가상 디스크 이미지 목록 확인

`xe vdi-list`

7. 네트워크 인터페이스 목록 확인

`xe vif-list`

8. USB 장치 확인

`lsusb`

9. 디스크 용량 및 사용 현황 확인

`df -h`

Step 2) 불필요한 외부 장치 비활성화

HV-20 (상)	가상화 장비 > 3. 가상머신 관리
	가상머신 콘솔 클립보드 복사&붙여넣기 기능 비활성화
개요	
점검 내용	가상 머신 콘솔 복사 기능 비활성화 여부 점검
점검 목적	가상 머신에 클립보드를 활용한 복사/붙여넣기 기능을 비활성화하여 파일 송·수신 기능을 통한 로그 기록이 저장되도록 하기 위함
보안 위협	가상 머신에 클립보드를 활용한 복사/붙여넣기 작업이 허용되어 있으면 파일 송·수신 기록이 로그에 저장되지 않아 로그 분석을 통한 침입 탐지가 불가능한 위험이 존재함
참고	※ ESXi 기본 비활성화 ※ XenServer 기본 비활성화
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : 가상 머신 콘솔 복사 기능이 비활성화 되어 있거나, 복사 제한이 설정된 경우
	취약 : 가상 머신 콘솔 복사 기능이 활성화 되어 있거나, 복사 제한이 설정되지 않은 경우
조치 방법	가상 머신 콘솔 복사 제한 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 가상 시스템 > [가상 머신 선택] > 설정 편집 > VM 옵션 > 고급 > 구성 매개 변수로 이동

Step 3) isolation.tools.copy.disable, isolation.tools.paste.disable 및

isolation.tools.setGUIOptions.enable 설정값 확인

Step 4) isolation.tools.copy.disable와 isolation.tools.paste.disable 각 변수 값을 TRUE로,

isolation.tools.setGUIOptions.enable 변수 값을 FALSE로 설정

또는, 각 매개 변수가 존재하지 않을 시, 해당 매개 변수 추가 및 값 설정

11. 가상화 장비

구성 매개 변수

+ 매개 변수 추가 - 매개 변수 삭제 🔍 검색

키	값
svga.autodetect	TRUE
vmware.tools.internalversion	0
vmware.tools.requiredversion	12294
migrate.hostLogState	none
migrate.migrationId	0
isolation.tools.copy.disable	TRUE
isolation.tools.paste.disable	TRUE
isolation.tools.setGUIOptions.enable	FALSE

28 항목

[가상 머신 콘솔 복사 기능 활성화 여부 확인]

HV-21 (상)	가상화 장비 > 3. 가상 머신 관리
	가상머신 콘솔 드래그 앤 드롭 기능 비활성화
개요	
점검 내용	가상 머신 드래그 앤 드롭 기능 비활성화 여부 점검
점검 목적	가상 머신에 대한 드래그 앤 드롭 기능 비활성화하여 파일 송·수신 기능을 통한 로그 기록이 저장되도록 하기 위함
보안 위협	가상 머신에 대한 드래그 앤 드롭 기능이 허용되어 있을 경우 파일 송·수신 기록이 로그에 저장되지 않아 로그 분석을 통한 침입 탐지가 불가능한 위험이 존재함
참고	※ ESXi 기본 비활성화
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : 가상 머신 콘솔 드래그 앤 드롭 기능이 비활성화되어 있거나, 제한 설정된 경우
	취약 : 가상 머신 콘솔 드래그 앤 드롭 기능이 활성화되어 있거나, 제한 설정되지 않은 경우
조치 방법	가상 머신 콘솔 드래그 앤 드롭 제한 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

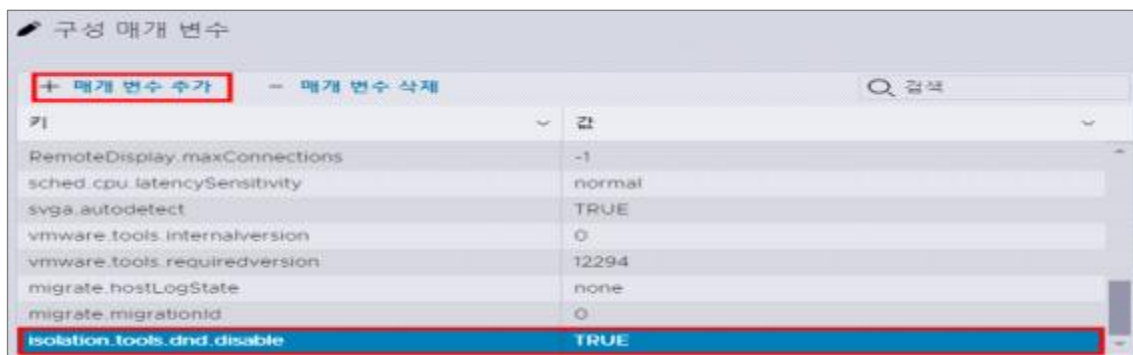
Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 가상 시스템 > [가상 머신 선택] > 설정 편집 > VM 옵션 > 고급 > 구성 매개 변수로 이동

Step 3) isolation.tools.dnd.disable 설정값 확인

Step 4) 매개 변수 값을 TRUE로 설정.

또는, 각 매개 변수가 존재하지 않을 시, 해당 매개 변수 추가 및 값을 TRUE로 설정



[가상 머신 콘솔 드래그 앤 드롭 기능 활성화 여부 확인]

11. 가상화 장비

HV-22 (상)	가상화 장비 > 4. 가상 네트워크 관리
	가상스위치 MAC 주소 변경 정책 비활성화
개요	
점검 내용	MAC 주소 변경 정책 비활성화 여부 점검
점검 목적	가상 스위치에 MAC 주소 변경 정책이 거부를 적용해 악의적인 사용자(또는 악성코드)가 장치 내의 MAC 주소를 변경을 방지하기 위함
보안 위협	가상 스위치에 MAC 주소 변경 정책이 설정되어 있을 경우, 악의적인 사용자(또는 악성코드)가 장치 내의 MAC 주소를 변경하여 스푸핑 등의 공격 위험이 존재함
참고	※ MAC 주소 변경 정책 : 가상 머신 내부에서 MAC 주소를 변경하는 것을 허용하는 정책
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : 가상 스위치 MAC 주소 변경 정책이 거부로 설정된 경우
	취약 : 가상 스위치 MAC 주소 변경 정책이 허용으로 설정된 경우
조치 방법	가상 스위치 MAC 주소 변경 정책 거부 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 네트워킹 > 가상 스위치 > [가상 스위치 선택] > 설정 편집 > 보안으로 이동

Step 3) MAC 주소 변경 정책 설정 확인

Step 4) 허용으로 설정되어 있을 경우, ‘거부’로 변경 후 해당 설정 저장



[MAC 주소 변경 정책 설정 확인]

HV-23 (상)	가상화 장비 > 4. 가상 네트워크 관리
	가상스위치 무차별(Promiscuous) 모드 정책 비활성화
개요	
점검 내용	무차별(Promiscuous) 모드 비활성화 여부 점검
점검 목적	가상 스위치에 무차별(Promiscuous) 모드를 비활성화 해 해당 가상 스위치로 다른 스위치로 전달되는 네트워크 트래픽 모니터링을 방지하기 위함
보안 위협	가상 스위치에 무차별(Promiscuous) 모드가 활성화된 경우, 비인가자가 해당 가상 스위치를 통해 다른 스위치로 전달되는 네트워크 트래픽을 모니터링 및 내부 정보 유출 위험이 존재함
참고	※ 무차별(Promiscuous) 모드: 자신에게 직접 전달되지 않은 모든 네트워크 트래픽 패킷을 수신하는 기능
점검 대상 및 판단 기준	
대상	VMware ESXi, XenServer
판단 기준	양호 : 가상 스위치 무차별(Promiscuous) 모드 정책 설정이 거부로 설정된 경우
	취약 : 가상 스위치 무차별(Promiscuous) 모드 정책 설정이 허용으로 설정된 경우
조치 방법	가상 스위치 무차별(Promiscuous) 모드 정책 거부 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속

<https://<VMware ESXi IP>>

Step 2) 네트워킹 > 가상 스위치 > [가상 스위치 선택] > 설정 편집 > 보안으로 이동

Step 3) 무차별 모드 정책 설정 확인

Step 4) 허용으로 설정되어 있을 경우, '거부'로 변경 후 해당 설정 저장

11. 가상화 장비



[무차별 모드 정책 설정 확인]

● XenServer

Step 1) 가상 스위치 Promiscuous 모드 조회

Step 2) XenServer CLI 접속 후, 다음 명령어 실행하여 uuid_of_pif/vif 확인

```
$ xe pif-list network-name-label=<네트워크 이름>
```

```
$ xe vif-list vm-name-label=<VM 이름>
```

Step 3) 다음 명령어 실행하여 promiscuous 값 확인

```
$ xe pif-param-list uuid=<uuid_of_pif>
```

```
$ xe vif-param-list uuid=<uuid_of_vif>
```

Step 4) 다음 명령어 실행하여 promiscuous 값 설정

```
$ xe pif-param-set uuid=<uuid_of_pif> other-config:promiscuous="false"
```

```
$ xe vif-param-set uuid=<uuid_of_vif> other-config:promiscuous="false"
```

HV-24 (상)	가상화 장비 > 4. 가상 네트워크 관리
	가상스위치 위조전송(Forged Transmits) 모드 정책 비활성화
개요	
점검 내용	가상 스위치 위조전송(Forged Transmits) 모드 비활성화 여부 점검
점검 목적	가상 스위치에 위조전송(Forged Transmits) 모드를 비활성화하여 네트워크 스니핑, 데이터 유출 등을 방지하기 위함
보안 위협	가상 스위치에 위조전송(Forged Transmits) 모드가 설정되어 있을 경우, 네트워크 스니핑, 데이터 유출 등의 보안 위협이 존재함
참고	※ 위조 전송(Forged Transmits) 모드: 가상 스위치가 수신하는 모든 트래픽을 연결된 모든 가상 NIC에게 전송하는 기능
점검 대상 및 판단 기준	
대상	VMware ESXi
판단 기준	양호 : 가상 스위치에 위조 전송(Forged Transmits) 모드 설정이 거부로 설정된 경우
	취약 : 가상 스위치에 위조 전송(Forged Transmits) 모드 설정이 허용으로 설정된 경우
조치 방법	위조 전송(Forged Transmits) 모드 거부 설정
조치 시 영향	일반적 경우 영향 없음

점검 및 조치 사례

● VMware ESXi

Step 1) Web 콘솔 페이지 접속 > <https://<VMware ESXi IP>>

Step 2) 네트워킹 > 가상 스위치 > [가상 스위치 선택] > 설정 편집 > 보안으로 이동

Step 3) 위조 전송 정책 설정 확인

Step 4) 허용으로 설정되어 있을 경우, '거부'로 변경 후 해당 설정 저장

11. 가상화 장비



[위조 전송 정책 설정 확인]

HV-25 (상)	가상화 장비 > 4. 가상 네트워크 관리
	주기적 보안 패치 및 벤더 권고사항 적용
개요	
점검 내용	가상화 장비 및 관리서버 등에 대해 주기적인 보안 패치와 벤더 권고사항 적용 여부를 확인
점검 목적	알려진 취약점을 제거하여 가상화 인프라의 안정성과 가용성을 확보하기 위함
보안 위협	패치 미적용 시 제로데이·원격코드실행 등 취약점이 악용되어 전체 가상화 인프라 침해 발생 가능
참고	-
점검 대상 및 판단 기준	
대상	공통
판단 기준	양호 : 패치 절차를 수립하여 주기적으로 패치 및 벤더 권고사항을 확인 및 적용하는 경우
	취약 : 패치 절차가 수립되어 있지 않거나 주기적으로 패치를 설치하지 않는 경우
조치 방법	장비별 제공하는 최신 취약점 정보를 파악 후 최신 패치 및 업그레이드를 수행
조치 시 영향	서비스 영향을 고려하여 벤더사와 협의 후 적용

점검 및 조치 사례

● 공통

Step 1) 주기적으로 보안 패치 및 벤더 권고사항을 검토 이후 적용

구분	보안패치 및 보안권고 정보제공 사이트
VMware ESXi, vCenter	https://support.broadcom.com/web/ecx/security-advisory
XenServer	https://support.citrix.com/support-home/home https://xenbits.xen.org/xsa
KVM	운영 중인 리눅스 배포판(Red Hat, Ubuntu, SUSE 등)의 공식 보안공지를 통해 확인
Nutanix	https://www.nutanix.com/trust/security-advisories